

Malware

The technical underpinnings of spyware, viruses, worms and ransomware — what each one actually is, how it gets in, and how it behaves once it's there.

What this key knowledge covers

This summary distils everything you need for **KK07 — Malware** in Cyber Security. Work through the explanations, then use the worked good-vs-weak answers to see exactly how marks are won and lost. Tick off the revision checklist at the end before a SAC or exam.

Study summary

What is malware?

Malware (short for *malicious software*) is any program written to harm, exploit or gain unauthorised access to a device, network or its data. It's an **umbrella term** — spyware, viruses, worms and ransomware are all *kinds* of malware, the way “sedan” and “ute” are kinds of car.

Three questions separate the four types. Keep them in your head — they are the spine of almost every malware answer:

- **Does it need a host?** Must it attach to another file/program to exist, or is it standalone?
- **Does it need a user to act?** Must someone open, run or click something for it to spread — or does it spread by itself?
- **What's the goal?** Spy and steal information, damage/replicate, spread and consume resources, or lock data for a ransom?

Spyware

Spyware hides on a device and **secretly monitors activity**, gathering information — keystrokes, screenshots, browsing history, login details — and **transmits it to a third party** without the user's knowledge or consent. Its goal is **surveillance and data theft**, not destruction. It usually doesn't need to replicate; it just needs to stay hidden and keep reporting back.

How it works — step by step

- **1 Delivery.** Usually *bundled* with something that looks legitimate — a “free” download, a cracked game, a dodgy browser extension — so the user installs it themselves (a **trojan** delivery).
- **2 Hide & persist.** Runs quietly as a background process, often disguised, and sets itself to start with the system.

- 3 **Collect.** A **keylogger** records every keystroke; other variants capture screens, webcam, clipboard or browser data.
- 4 **Exfiltrate.** Periodically sends the harvested data over the network to the attacker's server. A regular installs a "free aim-trainer" on rig 7. Bundled inside is a **keylogger**. It does nothing visible — no crashes, no pop-ups. But every time a staff member logs into the booking system or types a customer's card number at the counter PC, the keystrokes are quietly captured and posted to an overseas server. Nobody notices for weeks because *nothing breaks* — that silence is the whole point.

Spyware is a **hidden CCTV camera a burglar installs in your house**. It doesn't smash anything or steal furniture — it just watches, and quietly streams the footage out. You're robbed of *information*, and you may never see a broken window.

Virus

A **virus** is malicious code that **attaches itself to a legitimate host file or program**. It stays **dormant until that host is opened or run by a user** — that user action is what activates it. Once active it **replicates** by inserting copies of itself into other files, and may run a **payload** that corrupts or deletes data.

How it works — step by step

- 1 **Attach.** The virus embeds itself inside a host — an.exe, a macro inside a document/spreadsheet, a script.
- 2 **Wait.** It stays inert. Copying the infected file around does *not* trigger it.
- 3 **Trigger (user action!).** A user **opens or runs the host**. Only now does the virus code execute.
- 4 **Replicate.** It writes copies of itself into other files on that machine.
- 5 **Payload.** It may corrupt files, delete data, or open a backdoor.

A "sponsor" emails tournament_bracket.xlsm. It carries a **macro virus**. Sitting in the inbox it's harmless. The moment a staff member **opens it and enables macros**, the virus runs, copies itself into other spreadsheets on the counter PC, and scrambles the cells in the takings file. The key detail for the exam: **nothing happened until a human clicked**.

Like a **biological virus**: it can't do anything floating in the air. It needs to get *inside a host cell* (the file) and have that cell become active before it can hijack the machinery and make copies of itself.

Worm

A **worm** is **standalone** malware — it doesn't need a host file. It **self-replicates and spreads across networks automatically**, with **no user action required**, by exploiting **vulnerabilities** (e.g. unpatched software). As it multiplies it **consumes bandwidth and system resources**, slowing or crashing the network, and it can carry a **payload** such as installing a backdoor or dropping ransomware.

How it works — step by step

- 1 **Entry.** Slips onto one machine through an unpatched vulnerability or open network port.
- 2 **Scan.** Automatically scans the network for other reachable, vulnerable devices.
- 3 **Self-replicate.** Copies itself to each one **without anyone clicking anything**.

- **4 Repeat.** Each newly infected machine becomes a new launch point — spread is *exponential*.
- **5 Impact / payload.** Bandwidth and CPU get eaten alive; an optional payload does further damage.

One rig is months behind on updates. A worm exploits that hole at 2am. By open the next morning it has **copied itself across all 16 rigs and the counter PC — nobody touched a thing overnight**. The rigs are crawling because the worm is hammering the network scanning for more targets. This is the line students must hold: a **worm needs neither a host file nor a user**. That's exactly what separates it from a virus.

A worm is a **chain letter that posts itself**. A virus needs *you* to lick the stamp and mail it on. A worm finds every address in the building and sends itself to all of them while you sleep.

Ransomware

Ransomware encrypts the victim's files (or locks the whole device) using **cryptography**, then **demand a ransom — usually in cryptocurrency** — in exchange for the decryption key. Its goal is **extortion through denial of access**: the data is still there, you just can't read it. It's often delivered by phishing or by a worm, and modern variants **steal a copy of the data first** and threaten to leak it ("double extortion").

How it works — step by step

- **1 Delivery.** Arrives via a phishing attachment, a malicious download, or as a worm's payload.
- **2 (Optional) exfiltrate.** Quietly copies sensitive data out first — leverage for "pay or we publish."
- **3 Encrypt.** Uses strong encryption to scramble files; the key is held only by the attacker.
- **4 Demand.** Displays a ransom note with a deadline and a cryptocurrency wallet address.
- **5 Pressure.** A countdown threatens permanent loss or a price rise to force a fast decision.

The worm's payload was ransomware. It reaches the **NAS** and encrypts the membership database and every tournament video. A note appears: *"Your files are encrypted. Pay 0.4 BTC in 72 hours or lose them forever."* PixelPit can't take bookings, can't prove who's a member, and the footage for the regional final is locked. The fix that would have saved them isn't paying — it's an **offline backup** (KK09).

Ransomware is a **thief who puts their own padlock on your locker** and slides a note through the vent: pay up for the key. Your stuff is still inside — you just can't get to it. And a spare key kept at home (your backup) makes the whole threat collapse.

Notice how the types **combine**: a worm *delivered* the ransomware, and spyware-style *exfiltration* powered the double-extortion threat. Real incidents blend mechanisms — examiners love a scenario where you have to untangle which type did what.

Compare & contrast

This table is the single most exam-useful thing on the page. The virus-vs-worm row in particular comes up again and again.

Spyware watches. **Virus** needs a host and a click. **Worm** needs neither — it crawls the network alone. **Ransomware** locks your data and asks for money.

Infection Spread Simulator

This is PixelPit's network in 3D: the **counter PC** (front), **16 gaming rigs**, the **NAS**, and an external **attacker server**. Pick a malware type, hit **Release**, and watch how each one behaves *differently*. The point isn't the animation — it's seeing why a worm turns the whole room red on its own while a virus only moves when *you* click.

The counter PC is quietly infected, then secretly streams stolen data to the attacker server. No spread — surveillance only.

Exam practice

Short-answer style modelled on VCAA Applied Computing questions. Read the question, attempt it on paper, then open the responses and **self-mark honestly** — your marks feed the score dock in the corner.

"A virus and a worm are both viruses that infect your computer and spread to other files and make it run slow."

"A **virus** attaches to a host file and only spreads when a **user opens or runs that file**, so it needs human action. A **worm** is standalone and **self-replicates across the network automatically**, with **no user action**, by exploiting vulnerabilities."

- 1 mark — virus needs a host and a user to open/run it to spread.
- 1 mark — worm is standalone and spreads itself across a network without user action.

Identify the category of malware and explain how it operates to steal the card details.

"It's a virus that steals your passwords and money off the computer."

"It is **spyware** (specifically a keylogger). It runs **covertly in the background** so staff don't notice it, **records every keystroke** as card numbers are typed at the counter, and **transmits the captured data to the attacker** over the network — all without consent. The absence of any visible symptom is typical of spyware, whose goal is silent surveillance rather than damage."

- 1 mark — identifies the malware as spyware / a keylogger.
- 1 mark — runs covertly / hidden in the background (explains no symptoms).
- 1 mark — records keystrokes and transmits/sends the data to a third party.

Writing trainer

VCAA answers reward **structure**. Use **P·E·L**: make a **Point**, give **Evidence** (a technical detail or scenario example), then **Link** back to the question. Type a response below — the chips light up as you hit the technical terms an examiner looks for.

P: "A virus and a worm differ mainly in..." · **E**: "Specifically, a virus... whereas a worm..." · **L**: "This matters for PixelPit because..."

Glossary — examiner wording

KK07 names the threats; **KK08** sets them among the wider security threats, and **KK09** (reducing risk — patching, MFA, backups, updates) is where you explain how PixelPit stops each one. Quote backups against ransomware and patching against worms and you're connecting dot points the way top responses do.

Key terms

Term	Meaning
Malware	Umbrella term for any software written to harm, exploit or gain unauthorised access to systems or data.
Payload	The harmful action a piece of malware carries out once active (e.g. corrupting files, encrypting data, installing a backdoor).
Host file	A legitimate file or program that a virus attaches itself to in order to exist and travel.
Self-replication	Malware making copies of itself — viruses do this within files; worms do it across a network.
Exfiltration	Transmitting stolen data out of the network to an attacker.
Vulnerability	A weakness (e.g. unpatched software) that malware — especially a worm — exploits to get in or spread.
Double extortion	Ransomware tactic of stealing a copy of data before encrypting, then threatening to leak it as well.

Common traps & misconceptions

Exam trap

⚠ Exam trap · “virus” ≠ “malware” In everyday speech people call every infection a “virus.” In a VCE answer that costs marks. A **virus** is one *specific* type with specific behaviour. If a question asks you to identify a malware type, name the precise one (worm, ransomware, spyware...) and justify it from how it behaves.

Exam trap

⚠ Watch what the lab proves In **Virus** mode the infection only moves when you *click an infected machine to “share a file”*. In **Worm** mode you click **Release** once and then sit back — it spreads with **zero** further clicks. That difference is worth marks in “distinguish a virus from a worm” questions.

How to answer exam questions

Read the **command word** first — it sets how much to write. *State/Identify* wants a word or phrase; *Describe* wants features; *Explain* wants reasons and links; *Justify/Evaluate* wants a judgement backed by evidence. Always pull in the **scenario detail** rather than answering in the abstract. The examples below contrast a weak response with a strong one for the same question.

Q1. Distinguish · 2 marks

Distinguish between a **virus** and a **worm**.

✗ A weak answer

A virus and a worm are both bad software that harm your computer. (→ *True but doesn't distinguish them — 0.*)

✓ A strong answer

A **virus** attaches itself to a host file or program and only spreads when that file is run or shared by a user. A **worm** is **self-replicating** — it spreads across a network on its own, without needing a host file or user action. The key difference is that a worm propagates by itself, whereas a virus needs a carrier and human action.

How the marks are awarded

- 1 mark — virus needs a host file / user action to spread.
- 1 mark — worm self-replicates across a network without a host.

Q2. Explain · 3 marks

Explain how **ransomware** works and one measure that reduces the harm it causes.

✗ A weak answer

Ransomware locks your files and you pay money. Don't click bad links. (→ *Mechanism is thin; "don't click links" isn't the strongest mitigation — 1-2.*)

✓ A strong answer

Ransomware encrypts the victim's files so they become unusable, then demands a payment in exchange for the decryption key. The single most effective measure is maintaining **regular, offline (or otherwise isolated) backups**: if recent backups exist, the organisation can restore its data and refuse to pay, removing the attacker's leverage. Keeping software patched also closes the vulnerabilities ransomware uses to get in.

How the marks are awarded

- 1 mark — encrypts files and demands payment.
- 1 mark — a valid mitigation (offline backups / patching).
- 1 mark — explains why that mitigation reduces the harm.